

ISO 42001 & EU AI Act

1 AT A GLANCE

Dimension	ISO/IEC 42001:2023	EU AI Act
 Type	International management-system standard	Binding EU regulation
 Main purpose	Govern AI across the organization	Regulate AI systems, models and operators
 Focus	Policies, roles, risks, controls and continual improvement	Legal classification, obligations, conformity and enforcement
 Applicability	Any organization managing AI	Providers, deployers, importers, distributors and GPAI providers
 Scope	Organization-wide AI management system	System-, model-, use-case- and role-specific
 Certification	Organization can obtain AIMS certification	Certain high-risk systems require conformity assessment
 Enforcement	Certification, contractual and reputational consequences	Regulatory action, market restrictions and financial penalties
 Core question	How should AI be governed?	What legal obligations apply?

2

CORE DIFFERENCE

ISO/IEC 42001

Enterprise AI Governance
Operating System



Leadership and
accountability



AI policy and
objectives



Risk and impact
assessment



Lifecycle controls



Supplier governance



Monitoring and audits



Continual improvement

VS

EU AI Act

AI Regulatory Compliance
Framework



Prohibited AI
practices



High-risk AI
systems



Transparency
obligations



General-purpose AI
requirements



Human oversight



Technical
documentation



Conformity
assessment



Regulatory
enforcement

3

RISK APPROACH

Area	ISO/IEC 42001	EU AI Act
Risk model	Organization-defined	Legally prescribed
Prohibited AI	Managed through policy and controls	Certain practices are legally banned
High-risk AI	Based on internal risk criteria	Defined under the Act and its annexes
Transparency risk	Context-driven	Specific disclosure duties apply
GPAI	Governed within the AIMS	Separate legal obligations apply
Residual risk	Accepted and monitored by the organization	Must satisfy applicable legal requirements

**Important**

A system may be:

- Low-risk under the EU AI Act
- High-risk under internal enterprise criteria

Legal classification and enterprise risk assessment should remain separate.

4

GOVERNANCE COMPARISON

Capability	ISO/IEC 42001	EU AI Act
 AI policy	Explicitly required	Not universally required
 Leadership accountability	Explicit	Role-specific
 AI objectives	Required	No direct equivalent
 Roles and responsibilities	Required	Legally assigned by operator role
 Competence	Required	AI literacy required
 Internal audit	Required	Not universal
 Management review	Required	No direct equivalent
 Continual improvement	Core requirement	Compliance must be maintained

6

ASSESSMENT TYPES**ISO AI risk assessment**

Evaluates organizational AI risks

**AI system impact assessment**

Evaluates effects on people and society

**EU AI Act risk management**

Manages high-risk system risks

**Fundamental Rights Impact Assessment**

Evaluates fundamental-rights impacts

**Data Protection Impact Assessment**

Evaluates high-risk personal-data processing

**Cybersecurity assessment**

Evaluates threats and resilience

**Product-safety assessment**

Evaluates health and safety risks

**Key Principle**

These assessments may share evidence, but they are not interchangeable.

7

CERTIFICATION VS CONFORMITY ASSESSMENT

Area	ISO/IEC 42001 Certification	EU AI Act Conformity Assessment
Assesses	Organization's AIMS	Specific high-risk AI system
Result	Management-system certificate	Declaration of conformity and possible CE marking
Third party	Optional certification route	Depends on system category
Product compliance	Does not prove it	Designed to demonstrate it
Enterprise governance maturity	Provides assurance	Does not necessarily provide assurance



They are complementary:

ISO/IEC 42001 builds governance capability.
EU AI Act conformity demonstrates legal compliance for specific systems.

8

HOW THEY WORK TOGETHER



ISO/IEC 42001 Builds the Foundation

- Establish AI governance system
- Define policies, roles and controls
- Assess and manage risks
- Drive continual improvement
- Provide enterprise assurance



EU AI Act Ensures Legal Compliance

- Classify systems and roles
- Meet legal requirements
- Fulfil transparency obligations
- Undergo conformity assessment
- Comply with enforcement obligations



Outcome: Responsible and Compliant AI

Strong governance + legal compliance
= Trustworthy AI that is safe, ethical, and lawful.



Use ISO/IEC 42001 to run your AI program.
Use the EU AI Act to meet regulatory requirements.

9 GENERAL-PURPOSE AI

How ISO/IEC 42001 and the EU AI Act address GPAI

ISO/IEC 42001		EU AI Act	
Model governance	Supported	Model governance	Required
Technical documentation	Risk-based	Technical documentation	Mandatory
Downstream information	Supplier governance	Downstream information	Mandatory
Copyright policy	Legal-control driven	Copyright policy	Required
Training-content summary	Optional control	Training-content summary	Required
Systemic-risk assessment	Internal classification	Systemic-risk assessment	Legally required for qualifying models
Model evaluation	Risk-based	Model evaluation	Required for systemic-risk GPAI
Cybersecurity	Risk-based	Cybersecurity	Explicit requirement
Incident reporting	Internal process	Incident reporting	Statutory requirement

ISO/IEC 42001 + EU AI Act | Integrated AI governance and compliance

10 SUPPLIER & VALUE-CHAIN GOVERNANCE

Area	ISO/IEC 42001	EU AI Act
Vendor due diligence	Risk-based	Operationally necessary
Responsibility allocation	Contractual and organizational	Legally prescribed
Third-party model risk	External-resource control	Downstream obligations apply
Change notification	Supplier-control requirement	May affect provider status and conformity
Open-source AI	Must still be governed	Limited exemptions may apply
Exit planning	Recommended	Important for continuity and compliance

Key point: Contractual controls support governance, but legal operator obligations cannot be outsourced.

ISO/IEC 42001 + EU AI Act | Integrated AI governance and compliance

ISO 42001 - Timelines

Milestone	Timeline
ISO/IEC 42001:2023 published	18 December 2023
Organizations begin implementation	From December 2023 onward
Certification bodies begin accreditation/certification	Primarily during 2024 (varied by country and accreditation body)
Early adopter certifications	2024

Milestone	Timeline
Mainstream enterprise adoption	2025–2027 (ongoing)
First surveillance audit	12 months after certification
Second surveillance audit	24 months after certification
Recertification audit	36 months after certification

EU AI Act - Timelines

Date	Key milestone and obligations
21 April 2021	European Commission published the original AI Act proposal.
9 December 2023	European Parliament and Council reached political agreement.
13 June 2024	Final regulation formally signed.
12 July 2024	Published in the Official Journal of the EU.
1 August 2024	AI Act entered into force. (EUR-Lex)
2 February 2025	Prohibited AI practices, AI-system definition provisions and AI literacy obligations became applicable. (Digital Strategy)
2 August 2025	Governance provisions, national competent-authority requirements, penalties framework and obligations for new general-purpose AI models became applicable. (Digital Strategy)
2 August 2026	Most remaining AI Act provisions apply, including deployer obligations, post-market monitoring, transparency and enforcement powers. GPAI enforcement by the Commission also begins. (Digital Strategy)
2 December 2026	Updated deadline for technical transparency solutions used to identify or mark certain AI-generated content. (European Council)
2 August 2027	GPAI models placed on the market before 2 August 2025 must comply. (Digital Strategy)
2 December 2027	High-risk obligations apply to stand-alone high-risk systems , primarily Annex III use cases such as employment, education, biometrics, critical infrastructure and law enforcement. (European Council)
2 August 2028	High-risk obligations apply to AI systems embedded in regulated products, such as machinery, medical devices, vehicles, lifts and toys. (European Council)